Phishing Detection & Awareness Report

Prepared for: Future Interns, Cyber Security Task 2 (2026)

Prepared by: Patricia Wanjiru Wachira

Date: 20th October 2026

Scope: Analysis of three real phishing emails, risk classification, and prevention guidance for employees

1. Executive Summary

Phishing succeeds less because systems are weak and more because people cannot tell a fake email from a real one. This report analyses three real phishing emails from a public research collection, explains in plain language how each attack works, classifies each by risk, and turns the findings into practical guidance employees can follow.

All three emails were classified **Phishing**. Each impersonated a trusted brand or offered easy money, and each tried to push the reader into clicking a link or opening an attachment. The most important finding is that **the email that passed every technical authentication check (SPF, DKIM and DMARC) was still malicious**. Authentication shows who sent a message, not whether the sender can be trusted, so staff need to judge the content and context of a message, not only its technical checks.

#	Email	Lure	Classification	Confidence
1	Fake Bradesco/Livelo rewards alert	Reward points "expiring today"	**Phishing**	High
2	Fake Microsoft account security alert	"Unusual sign-in activity"	**Phishing**	High
3	Bitcoin "transaction" with PDF attachment	Unsolicited money offer	**Phishing**	High

2. Scope and Methodology

2.1 Approach

Each email was analysed with the same repeatable workflow:

1. **Collect** the sample from a public phishing-email repository (phishing_pot, used for study only; all analysis and wording in this report is original).
2. **Analyse headers**: sender, return path, reply-to, and the SPF, DKIM and DMARC results recorded by the receiving server.
3. **Inspect the sender domain and links**, comparing the domain the email claims with the domains it actually uses.
4. **Identify phishing indicators** using a standard checklist.
5. **Classify the risk** as Safe, Suspicious or Phishing.
6. **Document** the evidence and limitations.
7. **Write prevention guidance** for non-technical readers.

2.2 Tools

Tool	Purpose
Google Messageheader and MXToolbox	Reading and checking email headers
WHOIS / RDAP and DNS lookups	Ownership and registration of IP addresses and domains
Python (standard library email parser)	Extracting headers, links and attachment names without opening anything
VS Code and Markdown	Notes and evidence
Git and GitHub	Version control and publishing

2.3 Safe handling

- Links were never visited and attachments were never opened.
- Samples were read as plain text only.
- Every web address in this report is **defanged** (for example `hxxp://example[.]com`) so it cannot be clicked by accident.

2.4 Language

Email 1 was written in Portuguese. It was machine-translated into English with Claude AI so the message could be understood. The original text is quoted alongside the translation, and conclusions rely mainly on language-independent evidence (headers, domains, links).

3. Understanding Email Authentication

Three technical checks help a receiving mail server decide whether an email really came from the domain it claims. They appear in an email's hidden header.

Check	Question it answers	Everyday analogy
SPF	Is this server allowed to send email for the sender's domain?	A guest list at the door
DKIM	Is the message signed by the sender's domain and unchanged?	A tamper-proof seal
DMARC	Do SPF or DKIM match the address the reader sees, and what should happen if not?	Checking that the name on the seal matches the name on the envelope

Results can be `pass`, `fail`, `none` (nothing published or no signature), or an error (`temperror` for a temporary problem, `permerror` for a permanent configuration problem). **Errors and `none` are inconclusive, not proof of forgery.** A `pass` is not proof of safety either, as Email 3 shows.

4. Analysed Emails

4.1 Email 1: Fake Bradesco/Livelo "points expiring today" alert

Source: phishing_pot, sample-1.eml

Field	Value
Display name	BANCO DO BRADESCO LIVELO
From	`banco.bradesco@atendimento.com.br`
Return-Path	`root@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06`

Field	Value
Reply-To	Not present
Subject (original)	CLIENTE PRIME - BRADESCO LIVELO: Seu cartão tem 92.990 pontos LIVELO expirando hoje!
Subject (translated)	PRIME CLIENT - BRADESCO LIVELO: Your card has 92,990 LIVELO points expiring today!
Date	Tue, 19 Sep 2023 18:35:49 +0000
Sender IP	`137.184.34.4`
Attachments	None

Header analysis

Check	Result	Interpretation
SPF	`temperror`	The receiving server could not complete the check because a DNS lookup timed out. It was run against the envelope sender, a bare server hostname rather than a registered domain, so it would not have matched the visible From domain even if it had passed. Inconclusive.
DKIM	`none`	The message was not signed. Large legitimate organisations almost always sign their mail, so this is unexpected but not conclusive alone.
DMARC	`temperror`	Evaluation for `atendimento.com.br` could not complete. Inconclusive.

The envelope sender, `root@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06`, has the pattern of an automatically generated name for a rented cloud server. A bank's customer-mail system would not use the `root` account of a default-named server, which is strong evidence that the message did not originate from the bank.

Links

Defanged URL	Role	Finding
`hxxps://blog1seguimentmydomaine2bra[.]me/`	Main link	Random-looking name on an unrelated domain, with no apparent connection to Bradesco or Livelo. Not visited.
`hxxps://fonts[.]googleapis[.]com/` and `hxxps://fonts[.]gstatic[.]com`	Styling resources	Benign Google Fonts addresses used for appearance only.

Indicators identified

Indicator	Evidence
Brand impersonation	Display name and subject use "BRADESCO LIVELO"
Sender domain is not the bank's	`atendimento.com.br` (a generic word meaning "customer service") is not identifiable as Bradesco's own domain
Unconfigured server as sender	Envelope sender is `root@` on a default-style server hostname
No sender authentication	SPF temperror, DKIM none, DMARC temperror
Urgency	"expirando hoje" (expiring today)
Reward lure and flattery	A large points balance (92,990) and "CLIENTE PRIME" exclusive-customer framing
Suspicious link	Main link points to an unrelated domain

Verdict: Phishing (high confidence). The message presents itself as Bradesco/Livelo but was sent through a domain not identifiable as the bank's and from an envelope address that looks like a rented server, with no signature and no successful authentication. The subject combines urgency with a large reward, and the main link leads to an unrelated domain. These independent indicators are consistent with an attempt to harvest login or card details.

How the attack works. The attacker sends a message styled as a bank rewards notice claiming the reader has a large number of loyalty points about to expire. The urgency pushes the reader to act without thinking. The link leads away from the bank to a page controlled by the attacker, and anything entered there goes to the attacker, who can use it for fraud.

4.2 Email 2: Fake Microsoft account security alert

Source: phishing_pot, sample-10.eml

Field	Value
Display name	"Microsoft account team"
From	`no-reply@access-accsecurity.com`
Reply-To	`sotrecognizd@gmail.com`
Return-Path	`bounce@thcultarfdes.co.uk`
Subject	Microsoft account unusual signin activity
Date	Fri, 08 Sep 2023 05:47:04 +0000
Sender IP	`89.144.44.2`

Header analysis

Check	Result	Interpretation
SPF	`none`	No SPF record was published for the envelope domain `thcultarfdes.co.uk`, so the sending server could not be verified. It would also not align with the visible From domain.
DKIM	`none`	No signature. Established senders such as Microsoft sign their mail, so absence is unexpected.
DMARC	`permerror`	A permanent error, most likely a malformed or duplicated DMARC record on `access-accsecurity.com`, prevented evaluation. Inconclusive.

Four unrelated domains. The email names Microsoft in the display name, yet every technical address belongs to someone else.

Where it appears	Domain	Related to Microsoft?
Display name	"Microsoft account team"	Claims to be
From	`access-accsecurity.com`	Not identifiable as a Microsoft domain
Return-Path (checked by SPF)	`thcultarfdes.co.uk`	No
Reply-To	a free Gmail address	No
Link in body	`thebandalisty[.]com`	No

Sending IP. A registry lookup in 2026 shows the block containing `89.144.44.2` was registered to a small Polish hosting customer in February 2026. Because that is after the email was sent in September 2023, today's registration cannot be used to identify who sent the message, and this indicator was treated as inconclusive. The verdict does not depend on it.

Indicators identified

Indicator	Evidence
Brand impersonation	"Microsoft account team" display name with a non-Microsoft sending domain
Suspicious sender domain	`access-accsecurity.com` uses security-themed wording and is not identifiable as Microsoft's
Mismatched From, Reply-To and Return-Path	All three use different domains
Free webmail Reply-To	A corporate security notice would not ask for replies to a Gmail address
No sender authentication	SPF none, DKIM none, DMARC permerror
Fear-based subject	"unusual signin activity" plays on account-compromise anxiety

Indicator	Evidence
Suspicious link	`hxxp://thebandalisty[.]com/track/...` is unrelated to every other domain in the message

Verdict: Phishing (high confidence). Several independent indicators converge: a brand impersonated through an unrelated domain, three further mismatched domains, no authentication, and a fear-based subject. Together they point to a credential-harvesting attempt impersonating Microsoft.

How the attack works. The message looks like a security alert saying someone signed in to the reader's account from an unusual place. The goal is to alarm the reader into clicking the link, which is designed to lead to a fake sign-in page. Anything entered there goes to the attacker, who can then take over the account.

4.3 Email 3: Bitcoin "transaction" with a PDF attachment

Source: phishing_pot, sample-188.eml

Field	Value
Display name / From	Annikki Muckey `dorothyleejux3@gmail.com`
Return-Path	`dorothyleejux3@gmail.com`
Reply-To	Not present
To / Bcc	`addedbad@gmail.com` / collection mailbox in Bcc
Subject	`Bitcoin.Transaction.0.7495.BTC`
Date	Mon, 26 Dec 2022 00:57:07 -0800
Attachment	PDF named `GO.Get.Bitcoin.0.7495.BTC...pdf` (never opened)

Header analysis

Check	Result	Interpretation
SPF	`pass`	Sending IP `209.85.128.170` (a Google mail server) is authorised for `gmail.com`.

Check	Result	Interpretation
DKIM	`pass`	Signed by `gmail.com`; content unaltered in transit.
DMARC	`pass`	Aligned with the visible From domain `gmail.com`.
Origin	Gmail web submission	The sender's own IP address is not exposed in the headers.

Why passing authentication did not make this email safe. The attacker used an ordinary free Gmail account, and Google correctly authenticated its own customer. All three checks passed because the sender really did use Gmail, and none of them says anything about the sender's honesty.

Indicators identified

Indicator	Evidence
Free webmail, mismatched identity	Random-looking Gmail address with a display name that does not match it
Money-bait subject	`Bitcoin.Transaction.0.7495.BTC` with dots instead of spaces and no context
Unsolicited offer, no context	Body: "The main thing is to have time to withdraw your 11736$"
Filler text to evade filters	Body adds an unrelated sentence taken from a fictional story
Bait attachment	PDF named like a Bitcoin payout plus a long random string
Hidden destination	The PDF's structure shows a single image covering the page with a clickable link to a URL shortener (`hxxps://bit[.]ly/3v0Vpm2`), which hides the real destination. Found without opening the file; the destination itself was not confirmed.
Recipient hidden	The real target address is in Bcc, a bulk-mailing pattern
Spam filter agreement	The receiving Microsoft filter scored the message as spam and placed it in Junk

Verdict: Phishing (high confidence). Although all authentication checks passed, an unsolicited message from a free account offers a large sum with no context, adds filler text to evade filters, and attaches a PDF whose page is a clickable image linking to a URL shortener. The receiving mail system also scored it as spam.

How the attack works. The message dangles a large cryptocurrency payout and asks the reader to open the attachment. The PDF looks like a document but is really a picture with a link on top. Clicking it sends the reader through a shortened link to a page chosen by the attacker, typically one that asks for personal or financial details or tries to install something harmful.

5. Common Phishing Indicators

Comparing the three emails shows recurring patterns that any employee can learn to spot.

Indicator	Email 1	Email 2	Email 3
Impersonates a trusted brand	Yes	Yes	No (unknown sender)
Sender domain does not match the claimed organisation	Yes	Yes	Yes (free webmail)
Sender, bounce and reply addresses mismatch	Yes	Yes	No
Urgency or fear	Yes (expiring today)	Yes (account compromise)	Mild ("time to withdraw")
Reward or money lure	Yes	No	Yes
Suspicious or hidden link	Yes	Yes	Yes (shortened link in PDF)
Attachment as bait	No	No	Yes
Authentication failed or inconclusive	Yes	Yes	**No (all passed)**

Key lessons

1. **The message's content is usually the clearest evidence.** Mismatched domains, pressure, and unexpected rewards appeared in all three emails.
2. **Authentication errors are not evidence by themselves**, and authentication passes are not reassurance (Email 3).
3. **Display names are easy to fake.** The real address and domain matter.
4. **No single indicator decides.** Classification rests on several independent indicators.

6. Risk Classification

6.1 Framework

Level	Meaning	Typical signs	Recommended action
Safe	Consistent with a legitimate message	Known sender, matching domains, expected content, passing authentication, no pressure	Handle normally
Suspicious	Some warning signs but not enough to be sure	One or two anomalies, such as a mismatched domain or odd wording, without a clear malicious request	Do not click or reply; verify through another channel; report to IT
Phishing	Strong evidence of an attempt to deceive	Several independent indicators: impersonation, mismatched domains, pressure, suspicious links or attachments, requests for credentials or money	Do not interact; report; delete

6.2 Results

Email	Classification	Deciding evidence
1. Bradesco/Livelo	**Phishing**	Rented-server envelope sender, unrelated sender domain and link, urgency plus reward

Email	Classification	Deciding evidence
2. Microsoft alert	**Phishing**	Four unrelated domains, no authentication, fear-based subject
3. Bitcoin PDF	**Phishing**	Unsolicited money offer, bait attachment, hidden link, filter evasion text

7. Prevention Guidelines

7.1 For employees

1. **Pause before acting.** Urgency ("today", "within 24 hours", "account locked") is a manipulation tool.
2. **Check the real sender address**, not just the display name. Tap or hover to see the full address.
3. **Compare domains.** If a message claims to be from a bank or Microsoft but the domain is unrelated, treat it as phishing.
4. **Do not click links in unexpected messages.** Open the organisation's site by typing its address yourself or using its official app.
5. **Never open unexpected attachments**, especially PDFs, archives and documents that promise money or invoices.
6. **Be suspicious of rewards and windfalls**, such as expiring points, prizes and crypto payouts.
7. **Never share passwords or one-time codes** by email, message or phone.
8. **Report and delete.** Use your organisation's reporting channel instead of ignoring it.
9. **If you clicked or entered details**, report it immediately, change the affected passwords and turn on multi-factor authentication.

7.2 For organisations

Control	Why it helps
Publish SPF, DKIM and DMARC with an enforcing DMARC policy for your own domains	Stops attackers spoofing your exact domain

Control	Why it helps
Multi-factor authentication on all accounts	Limits damage if a password is stolen
Email filtering that flags lookalike domains, free-webmail senders using internal names, and risky attachments	Blocks many attacks before they reach staff
A one-click "report phishing" button	Makes reporting fast, which speeds up the response
Regular awareness training with realistic examples	Builds recognition skills
Clear incident process	Reduces time between a click and containment

8. Do's and Don'ts for Employees

Do	Don't
Check the sender's full address and domain	Trust the display name alone
Type the website address yourself or use the official app	Click links in unexpected emails
Verify unusual requests through a separate channel (call a known number)	Reply to the message to ask whether it is real
Report suspicious emails to IT or security	Forward them to colleagues or ignore them
Use multi-factor authentication	Share passwords or one-time codes
Treat unexpected attachments as unsafe	Open attachments promising money, invoices or prizes
Slow down when a message is urgent	Act under pressure
Change passwords at once if you clicked	Hide a mistake out of embarrassment

9. Limitations

- **Dated samples.** The emails are from 2022 and 2023. Registration data and reputation checked in 2026 may differ from what was true at sending time, so such data was used only as context, never as primary evidence.
- **Inconclusive authentication results.** SPF and DMARC errors and `none` results were reported accurately as inconclusive and not counted as proof of forgery.
- **Links and attachments not followed.** Their destinations and contents were inferred from structure, not confirmed.
- **Translation.** Email 1 was machine-translated, which may miss nuance. Conclusions rely mainly on headers, domains and links.
- **Sample set.** All three samples are phishing. The set contains no Suspicious or Safe example, so the full classification scale was not exercised against real messages.
- **Small sample size.** Three emails show patterns but do not represent all phishing.

10. Conclusion

The three analysed emails used different lures (a reward, an account alert and a money offer) but shared the same weaknesses: mismatched identities, pressure to act, and links or attachments that hide their real destination. The Bitcoin email passed every technical check yet was still malicious, which shows that employees need to judge content and context, not rely on technical signals alone. A short routine of pausing, checking the real sender, avoiding links and attachments from unexpected messages, and reporting anything doubtful removes most of the risk these attacks depend on.

Appendix: Sources and Defanged Indicators

Sources. Samples are from the public phishing_pot collection (rf-peixoto), used for study only: sample-1.eml, sample-10.eml and sample-188.eml.

Email	Defanged indicators
1	`hxxps://blog1seguimentmydomaine2bra[.]me/`, `atendimento[.]com[.]br`, IP `137.184.34.4`
2	`access-accsecurity[.]com`, `thcultarfdes[.]co[.]uk`, `thebandalisty[.]com`, IP `89.144.44.2`

Email	Defanged indicators
3	`hxxps://bit[.]ly/3v0Vpm2`, `dorothyleejux3@gmail[.]com`